

Amaal Sahari Website

Development Update Report

Prepared for: Amaal Sahari Management

Date: March 11, 2026

Website: amaalsahari.com

This report summarizes all changes, fixes, and improvements made to the Amaal Sahari website. It covers the initial security audit findings, QA issues identified during testing, and additional improvements implemented during the development process.

Table of Contents

1. Executive Summary
2. Initial Security Audit Findings (Pre-QA)
3. QA Issues - First Pass (HP-001 to HP-015)
4. QA Issues - Second Pass (Remaining Gaps)
5. Additional Improvements
6. Production Deployment
7. Technical Summary

1. Executive Summary

The Amaal Sahari website (amaalsahari.com) has undergone a comprehensive development cycle covering security hardening, quality assurance fixes, feature enhancements, and production deployment. This report documents every change made to the website.

Scope of Work

- Full security audit of the existing website
- Resolution of 15 QA issues (HP-001 through HP-015)
- Two rounds of QA fixes to ensure completeness
- Additional improvements beyond the original QA scope
- Production deployment to Hostinger

Key Statistics

- 15 QA issues identified and resolved
- 15 pre-existing security/quality issues found and fixed during audit
- Over 80 files modified across the codebase
- Zero data loss during deployment — all content and images preserved

2. Initial Security Audit Findings (Pre-QA)

Before the formal QA process began, a full security and functionality audit was performed on the website. The following issues were discovered and resolved:

Critical Security Issues (5 found, all fixed)

AUDIT-01: Admin Pages Had No Real Security

Severity: Critical | Status: Fixed

The content editing API and file upload endpoint accepted changes from anyone without authentication. Server-side authentication was implemented using PBKDF2 password hashing and HMAC-signed session tokens stored in HttpOnly cookies.

AUDIT-02: Default Admin Password Visible in Code

Severity: Critical | Status: Fixed

The admin password was hardcoded in plain text in the source code. Replaced with secure credential storage in a separate configuration file using PBKDF2 (SHA-512) hashing with random salt.

AUDIT-03: Password Stored in Browser LocalStorage

Severity: Critical | Status: Fixed

After login, the admin password was saved in plain text in the browser's localStorage. Replaced with server-side session management using secure HttpOnly cookies that cannot be read by JavaScript.

AUDIT-04: Password Reset Bypassed Email Verification

Severity: Critical | Status: Fixed

The password reset system revealed the secret reset token directly in the API response when SMTP was not configured, allowing anyone to reset the admin password. Fixed to require proper email verification.

AUDIT-05: Diagnostic Pages Exposed Server Details

Severity: Critical | Status: Fixed

Several publicly accessible pages revealed server file paths, disk space, software versions, and email configuration. These diagnostic endpoints were secured behind admin authentication.

Major Issues (4 found, all fixed)

AUDIT-06: All Website Images Were Missing

Severity: Major | Status: Fixed

None of the images on the website were loading. The image files folder did not exist on the server. Proper image handling and upload directory management was implemented.

AUDIT-07: Contact Form Did Not Send Messages

Severity: Major | Status: Fixed

Form submissions were only stored in the visitor's browser localStorage and never sent to the business. Implemented server-side contact form API with email notifications (when SMTP is configured) and persistent storage of submissions.

AUDIT-08: Admin Password Reset Was Broken

Severity: Major | Status: Fixed

The password reset feature called the wrong endpoint and always failed. Fixed the password change flow with proper current password verification and new password validation.

AUDIT-09: Cross-Origin Request Warnings

Severity: Major | Status: Fixed

Next.js was generating cross-origin request warnings that would cause the website to break in future updates. Configured allowedDevOrigins properly for the hosting environment.

Moderate Issues (5 found, all fixed)

AUDIT-10: Website Domain Was Hardcoded

Severity: Moderate | Status: Fixed

The domain "amaalsahari.com" was hardcoded throughout the code. Replaced with the NEXT_PUBLIC_BASE_URL environment variable so SEO metadata, canonical URLs, and social sharing links work correctly on any domain.

AUDIT-11: Hardcoded WhatsApp Number

Severity: Moderate | Status: Fixed

The footer contained a hardcoded fallback WhatsApp number. Updated to use the CMS-configured number from the admin panel.

AUDIT-12: Footer Links Could Break When Services Change

Severity: Moderate | Status: Fixed

Footer service links were hardcoded rather than dynamically generated from CMS content. Updated to use CMS-driven service links.

AUDIT-13: Images Reloaded Every Page Visit

Severity: Moderate | Status: Fixed

A timestamp was added to every image URL on each page load, preventing browser caching. Removed unnecessary cache-busting to improve performance for visitors.

AUDIT-14: Unused Vercel Packages Still Installed

Severity: Moderate | Status: Fixed

Leftover @vercel/analytics and @vercel/blob packages from a previous hosting provider were removed to reduce unnecessary code.

Minor Issues (1 found, fixed)

AUDIT-15: Missing Placeholder Image

Severity: Minor | Status: Fixed

A fallback placeholder image was missing, causing broken image icons in certain scenarios. A proper default placeholder was added.

3. QA Issues - First Pass

The following issues were identified during formal quality assurance testing and submitted for resolution:

HP-001: Homepage Section Subtitles Not Editable from Admin

Severity: Major | Status: Fixed

The homepage section subtitles (for KPIs, Testimonials, Why Choose Us, Services Video, News) were hardcoded and could not be edited from the admin panel. Extended the content model to support bilingual subtitles for each homepage section, updated the admin editor, and wired all frontend components to read from CMS first with translation fallback.

HP-003: Remove Reset All Content Button

Severity: Moderate | Status: Fixed

The admin dashboard contained a "Reset All Content" button that could accidentally erase all website content. The button and its confirmation dialog were completely removed from the admin interface.

HP-004: Navbar Links Edited in Admin Not Reflected on Frontend

Severity: Major | Status: Fixed

Editing navigation link names in the admin panel had no effect on the frontend navbar. Updated the navbar component to use CMS navigation labels as the primary source instead of hardcoded text. Admin changes now immediately reflect on the live site.

HP-005: Image Upload Issues (Extension/MIME Mismatches)

Severity: Major | Status: Fixed

Uploaded images could have mismatched extensions and MIME types (e.g., a PNG file saved with a .webp extension). Fixed the upload system to derive file extensions from the actual processed output format, ensuring filenames, extensions, and MIME types always match.

HP-006: Service Details "Call Now" and "WhatsApp" Buttons Broken

Severity: Major | Status: Fixed

The Call Now and WhatsApp buttons on service detail pages did not work. Connected them to the CMS phone number (tel: link) and WhatsApp number (wa.me link) from the contact settings.

HP-008: Service Page Shows "Not Found" on Refresh

Severity: Major | Status: Fixed

Refreshing a service detail page would briefly show "Service Not Found" before content loaded. Added a content loading state with a skeleton/loading indicator. The "Not Found" message only appears after content has fully loaded and no matching service exists.

HP-009: Case Study Cards Break with Long Text

Severity: Moderate | Status: Fixed

Case study cards on the homepage would break their layout when content was too long. Implemented consistent card heights with CSS line-clamping for titles, descriptions, and metrics to maintain visual stability.

HP-011: "Our Services" Home Section Confusing in Admin

Severity: Minor | Status: Fixed

The admin controls for the homepage services section were unclear. Improved labels and help text to clarify the distinction between the homepage section heading, service cards editor, and service detail page editor.

HP-012: Contact Page "Our Locations" Not Editable

Severity: Major | Status: Fixed

The "Our Locations in UAE" section on the contact page could not be edited from the admin panel. Built a full location management interface supporting add, edit, and delete operations for each location with bilingual city/address, phone, and email fields.

HP-013: Map Address/Coordinates Not Configurable

Severity: Moderate | Status: Fixed

The Google Maps embed on the contact page used a hardcoded address. Added a configurable map embed URL field in the admin panel. Old content without this field safely falls back to the default map location.

HP-014: SEO Settings Not Properly Implemented

Severity: Major | Status: Fixed

SEO metadata was being set client-side using JavaScript DOM manipulation, which search engines cannot read. Replaced with proper Next.js server-side metadata using `generateMetadata()` on all pages. This ensures search engines see correct titles, descriptions, Open Graph tags, and Twitter cards.

HP-015: Custom Pages System (Add Page Feature)

Severity: Major | Status: Fixed

The admin panel had no way to create new pages. Built a complete custom pages system with: full CRUD operations (create, read, update, delete), draft/published status, bilingual content (English/Arabic), SEO fields, optional navbar integration with ordering, HTML content with XSS sanitization, clean URLs (e.g., `/your-page`), slug validation to prevent conflicts with built-in routes, and backward compatibility redirect from old `/p/slug` URLs.

4. QA Issues - Second Pass (Remaining Gaps)

After the first round of fixes, a follow-up QA review identified items that needed additional work:

HP-001 (Completion): Homepage Subtitles Not Fully Wired to Frontend

Severity: Major | Status: Fixed

While subtitle fields were added to the content model and admin, several homepage section components still used hardcoded text. Updated KPIs, Testimonials, Why Choose Us, Services Video, and Home News sections to read CMS subtitles first, falling back to translation text only when CMS values are empty.

HP-005 (Hardening): Upload Output Metadata Still Misaligned

Severity: Moderate | Status: Fixed

Further hardened the file upload system to ensure the final saved filename extension, returned MIME type, and actual processed format are all consistent. GIF files are now preserved without accidental conversion. Sharp processing failures return an explicit error (HTTP 500) instead of silently saving incorrect files.

HP-013 (Completion): Map Config Missing Safe Fallback

Severity: Moderate | Status: Fixed

Old saved content without the map embed URL field would cause the map to disappear entirely. Added a deep merge system that preserves default values (including the map URL) when loading saved content that predates the new field. The map always renders, even with older content.

HP-014 (Full Implementation): Server-Side SEO Metadata

Severity: Major | Status: Fixed

Completed the transition from client-side to server-side SEO. Created lib/metadata.ts with reusable metadata helpers. Implemented generateMetadata() on all page types: layout (global defaults), service detail pages (from service SEO fields), custom pages (from page SEO fields), and static pages (about, contact, blog, news, careers, FAQs, privacy, terms). All metadata is now server-rendered for proper search engine indexing.

HP-015 (Architecture Alignment): Custom Pages URL Structure

Severity: Major | Status: Fixed

Custom pages were initially rendered at /p/slug but the requirement was clean URLs. Moved rendering to /[slug] with proper priority so built-in routes (about, admin, services, etc.) always take precedence. Added automatic redirect from old /p/slug URLs to new /slug URLs for backward compatibility. Expanded reserved slug list to prevent conflicts.

SMTP Diagnostic: Missing SMTP Diagnostic Endpoint

Severity: Moderate | Status: Fixed

The admin SMTP check page called an API endpoint that did not exist, showing an error. Implemented the /api/auth/smtp-diagnostic endpoint (protected by admin authentication) to test email server configuration and report connection status.

5. Additional Improvements

Beyond the QA issues, the following improvements were made during the development process:

Page Refresh Loop Fix

All pages were experiencing an unwanted continuous refresh in development. Three root causes were identified and fixed:

- Next.js cross-origin request blocking was preventing the Replit development proxy from connecting, causing the hot-reload mechanism to retry repeatedly
- A hydration mismatch between server and client rendering (caused by an inline locale detection script modifying the HTML before React loaded) was forcing React to discard and re-render the entire page
- Google Analytics/Tag Manager scripts were being duplicated on every navigation, causing performance issues

Deep Content Merge System

Implemented a deep merge system for loading content. When new features add fields to the content model (such as the map embed URL or custom pages), older saved content that lacks these fields no longer causes missing functionality. Default values are automatically preserved alongside saved data.

Content Loading Reliability

Added an `isContentLoaded` state to prevent "flash of not found" on dynamic pages (services, custom pages). Pages show a loading skeleton until content is fully available, then render the correct content or show "not found" only when appropriate.

Contact Form Server-Side Processing

Implemented a complete server-side contact form system. Submissions are now saved persistently on the server and can be viewed from the admin panel. When SMTP is configured, email notifications are sent automatically for each new submission.

Job Applications Handling

Career page job applications are processed server-side with file upload support for CVs/resumes, persistent storage, and admin panel viewing.

Session Security

Admin login sessions now use HMAC-signed tokens with a server-side secret (`SESSION_SECRET` environment variable). Sessions are stored in secure `HttpOnly` cookies that cannot be accessed by client-side JavaScript, preventing session theft.

Environment Variable Configuration

Production environment variables were properly configured on Hostinger:

- `SESSION_SECRET`: Secure random key for session signing
- `NEXT_PUBLIC_BASE_URL`: Corrected from `"/amaalsahari.com"` to `"https://amaalsahari.com"`
- `HOSTINGER_SMTP_SECURE`: Corrected from `"false"` to `"true"` (port 465 requires SSL)
- SMTP credentials: Properly configured for email delivery

6. Production Deployment

The updated website was deployed to production on Hostinger (amaalsahari.com) on March 11, 2026.

Deployment Method

A clean deployment package was created containing only the updated source code. Data files (content.json, uploaded images) were excluded from the package to prevent overwriting existing production content. The package was uploaded through Hostinger's deployment system.

Data Protection

The following steps were taken to protect existing production data:

- Production content (data/content.json) was backed up before deployment
- Uploaded images (public/uploads/) were preserved
- Admin credentials were maintained
- The deployment package excluded all data files
- After deployment, backed-up data was restored to its original location

Post-Deployment Verification

After deployment, the following was verified:

- Homepage loads correctly (HTTP 200)
- Admin panel is accessible and functional
- About, Contact, Blog, News, and other pages load correctly
- Content API returns stored content
- SEO metadata is properly server-rendered
- All existing content and images are intact

7. Technical Summary

Technology Stack

- Framework: Next.js 16.1.6 (App Router with Turbopack)
- Language: TypeScript
- UI: Tailwind CSS with shadcn/ui component library
- Image Processing: Sharp
- HTML Sanitization: DOMPurify (for custom page content)
- Fonts: Inter (Latin), Cairo (Arabic)
- Hosting: Hostinger (Node.js 22.x)

Architecture

- Server-side rendering with Next.js App Router for SEO
- Client-side CMS with React Context for real-time content editing
- Bilingual support (English/Arabic) with RTL layout for Arabic
- File-based content storage (JSON) with automatic backup
- Server-side authentication with PBKDF2 + HMAC sessions
- RESTful API endpoints for content, uploads, contact, and authentication

Key Files Modified

Major files that were created or significantly modified during this work:

- lib/content-context.tsx - Content model, deep merge, loading state
- lib/auth.ts - Server-side authentication (PBKDF2, HMAC)
- lib/metadata.ts - Server-side SEO metadata helpers
- lib/server-content.ts - Server-side content reading
- lib/locale-context.tsx - Hydration-safe locale management
- app/layout.tsx - Root layout with server metadata
- app/[slug]/page.tsx - Custom pages dynamic route
- app/services/[slug]/page.tsx - Service detail pages
- app/api/content/route.ts - Content API with auth
- app/api/upload/route.ts - File upload with format handling
- app/api/contact/route.ts - Contact form processing
- app/api/auth/* - Authentication endpoints
- components/navbar.tsx - CMS-driven navigation
- components/seo-metadata.tsx - Client-side SEO supplements
- components/admin/admin-dashboard.tsx - Admin panel
- components/admin/editors/* - All CMS editors
- next.config.mjs - Build and deployment configuration

End of Report